

RemediationMeta

Attività di remediation – Metasploitable

Target: 192.168.60.101 | Nessus: Basic Network Scan | Scanner: Local Scanner

Obiettivo della remediation

Dopo la scansione iniziale sono ho scelte tre vulnerabilità Critical da trattare. Gli interventi sono stati eseguiti direttamente sulla VM Metasploitable e successivamente verificati con una nuova scansione Nessus.

Finding	Intervento eseguito	Evidenza
VNC Server 'password' Password	Cambio della password VNC e riavvio del server	Terminale + porta 5900
Bind Shell Backdoor Detection	Blocco in ingresso della porta TCP 1524 con iptables	Regola DROP verificata
SSL Version 2 and 3 Protocol Detection	Modifica della configurazione SMTP e riavvio Postfix	Configurazione + verifica finale Nessus

Remediation VNC – password debole

Nessus aveva verificato l'accesso al servizio VNC sulla porta 5900/tcp utilizzando la password predefinita 'password'. La prima operazione è stata individuare il programma vncpasswd e modificare il file di autenticazione /root/.vnc/passwd. La nuova password non viene riportata nella relazione.

Vulnerabilities 78

Critical VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Remote logged in using a password of "password".

To see debug logs, please visit individual host

Port

Hosts

5900/tcp/vnc 192.168.60.101

Plugin Details

Severity: Critical

ID: 61708

Version: 1.2.9

Type: remote

Family: Gain a shell remotely

Published: August 26, 2012

Modified: September 24, 2015

Risk Information

Risk Factor: Critical

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/A.C

Vulnerability Information

Default Account: true

Exploited by Nessus: true

Evidenza iniziale del finding VNC Server 'password' Password.

```
sudo vncpasswd /root/.vnc/passwd
```

Durante la modifica è comparso il messaggio che la versione di TightVNC presente nella VM limita la password a 8 caratteri. La password è stata comunque sostituita correttamente.

```
msfadmin@metasploitable:~$ which vncpasswd
/usr/bin/vncpasswd
msfadmin@metasploitable:~$ sudo vncpasswd /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$
```

Modifica della password VNC con vncpasswd.

Per applicare la nuova password è stato necessario riavviare il server VNC. Durante il riavvio sono stati rimossi i file di lock X rimasti dalla precedente istanza e il server è stato avviato nuovamente sulla display :0.

```
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
msfadmin@metasploitable:~$ sudo vncserver :0

Warning: metasploitable:0 is taken because of /tmp/.X0-lock
Remove this file if there is no X server metasploitable:0
A VNC server is already running as :0
msfadmin@metasploitable:~$ ps aux | grep -E '[X]tightvnc|[X]org'
msfadmin@metasploitable:~$ sudo rm -f /tmp/.X0-lock
msfadmin@metasploitable:~$ sudo vncserver :0

Warning: metasploitable:0 is taken because of /tmp/.X11-unix/X0
Remove this file if there is no X server metasploitable:0
A VNC server is already running as :0
msfadmin@metasploitable:~$ sudo ls -la /tmp/.X11-unix/
total 8
drwxrwxrwt 2 root root 4096 2026-10-03 10:36 .
drwxrwxrwt 4 root root 4096 2026-10-03 10:51 ..
srwxrwxrwx 1 root root  0 2026-10-03 10:36 X0
msfadmin@metasploitable:~$ sudo fuser /tmp/.X11-unix/X0
msfadmin@metasploitable:~$ sudo rm -f /tmp/.X11-unix/X0
msfadmin@metasploitable:~$ sudo vncserver :0

New 'X' desktop is metasploitable:0

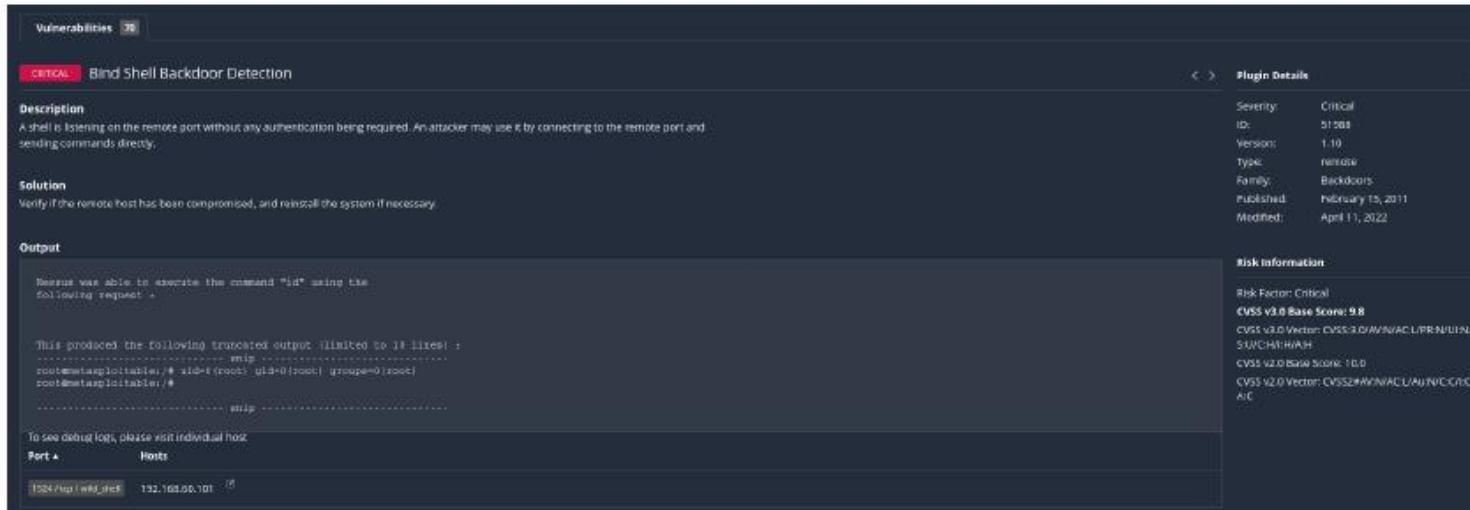
Starting applications specified in /home/msfadmin/.vnc/xstartup
Log file is /home/msfadmin/.vnc/metasploitable:0.log

msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900          0.0.0.0:*             LISTEN      5052/Xtightvnc
```

Riavvio di Xtightvnc e verifica della porta 5900/tcp.

Remediation Bind Shell – TCP 1524

Il bind shell era esposto sulla porta TCP 1524 ed era gestito da xinetd. Poiché la traccia consente di utilizzare il firewall per una delle remediation, è stata applicata una regola iptables per bloccare le connessioni in ingresso verso la porta.



Vulnerabilities 38

CRITICAL Bind Shell Backdoor Detection

Description
A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution
Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

Reveree was able to execute the command "id" using the following request ->

This produced the following truncated output (limited to 18 lines):

```
----- snip -----
root@metasploitable:/# id=$(root) gid=0(root) groups=0(root)
root@metasploitable:/#
----- snip -----
```

To see debug logs, please visit individual host

Port	Hosts
1524/tcp xinetd	132.168.0.101

Plugin Details

Severity: Critical
ID: 51588
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2011
Modified: April 11, 2022

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/H:A/H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS#AV:N/AC:L/AU:N/C:C/C:C/A:C

Evidenza iniziale del Bind Shell Backdoor Detection.

```
sudo iptables -I INPUT -p tcp --dport 1524 -j DROP
```

La presenza della regola è stata verificata con:

```
sudo iptables -L INPUT -n --line-numbers | grep 1524
```

verificata.

```
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900        0.0.0.0:*          LISTEN    5052/Xtightvnc
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900        0.0.0.0:*          LISTEN    5052/Xtightvnc
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep -E ':25|:5432'
tcp        0      0 0.0.0.0:5432        0.0.0.0:*          LISTEN    4256/postgres
tcp        0      0 0.0.0.0:25          0.0.0.0:*          LISTEN    4411/master
tcp6       0      0 :::5432             :::*               LISTEN    4256/postgres
<conf -n | grep -Ei 'smtpd_tls|smtpd_use_tls|smtpd_tls_protocols|smtpd_tls_mandatory_protocols'
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_session_cache_database = btree:${data_directory}/smtpd_scache
smtpd_use_tls = yes
msfadmin@metasploitable:~$ sudo grep -n "1524" /etc/xinetd.conf
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep ':1524'
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN    4436/xinetd
msfadmin@metasploitable:~$ sudo grep -Rni "1524\\|bind\\|shell" /etc/xinetd.d/ 2>/dev/null
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep ':1524'
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN    4436/xinetd
msfadmin@metasploitable:~$ sudo iptables -I INPUT -p tcp --dport 1524 -j DROP
msfadmin@metasploitable:~$ sudo iptables -L INPUT -n --line-numbers | grep 1524
1 DROP     tcp -- 0.0.0.0/0            0.0.0.0/0            tcp dpt:1524
msfadmin@metasploitable:~$
```

Regola DROP verificata sulla porta TCP 1524.

La porta può rimanere in ascolto localmente perché il servizio xinetd non è stato rimosso; l'intervento agisce sul traffico in ingresso e impedisce l'accesso remoto alla porta 1524.

Remediation SSLv2 / SSLv3

Il plugin 20007 interessava i servizi SMTP (25/tcp) e PostgreSQL (5432/tcp) e indicava il supporto a SSLv2/SSLv3. Inizialmente sono stati impostati i parametri Postfix per escludere i protocolli obsoleti.

```
sudo postconf -e 'smtpd_tls_protocols = !SSLv2,!SSLv3'
sudo postconf -e 'smtpd_tls_mandatory_protocols = !SSLv2,!SSLv3'
```

La verifica ha mostrato che la versione molto vecchia di Postfix della VM non riconosce smtpd_tls_protocols. Per questo motivo, per il servizio SMTP del laboratorio è stato disabilitato l'uso di TLS con smtpd_use_tls = no e Postfix è stato riavviato.

```
sudo postconf -e 'smtpd_use_tls = no'
sudo /etc/init.d/postfix restart
```

È stato inoltre riavviato PostgreSQL 8.3 dopo il controllo della configurazione SSL. La verifica finale è stata demandata alla nuova scansione Nessus, che costituisce la prova conclusiva sull'effettiva scomparsa del finding 20007.

The screenshot shows the Nessus interface with the 'Vulnerabilities' tab selected. The specific finding is 'SSL Version 2 and 3 Protocol Detection' (ID: 20007), which is marked as 'CRITICAL'. The description explains that the remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0, which are affected by several cryptographic flaws, including insecure padding schemes and session renegotiation. It notes that although SSL/TLS has a secure means for choosing the highest supported version, many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely. The solution is to consult the application's documentation to disable SSL 2.0 and 3.0, and use TLS 1.2 (with approved cipher suites) or higher instead. The 'See Also' section provides links to various security advisories and research papers. On the right, the 'Plugin Details' section shows the severity as 'Critical', the ID as '20007', the version as '1.35', the type as 'Remote', the family as 'Service Detection', and the published/modified dates. The 'Risk Information' section shows a risk factor of 'CRITICAL', a CVSS v3.0 base score of 9.8, and several CVSS vectors. The 'Vulnerability Information' section at the bottom indicates it is 'In the News: True'.

Hosts	Vulnerabilities	Remediations	Notes	History
	CRITICAL SSL Version 2 and 3 Protocol Detection			

Description
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in FCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution
Consult the application's documentation to disable SSL 2.0 and 3.0. Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also
<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<https://www.nessus.org/bsc/2007>
<https://www.nessus.org/2007/04/04>
<https://www.schneier.com/academic/paper-ssl.pdf>
<https://www.nessus.org/2007/04/04>

Plugin Details

Severity:	Critical
ID:	20007
Version:	1.35
Type:	Remote
Family:	Service Detection
Published:	October 12, 2005
Modified:	April 13, 2016

Risk Information

Risk Factor:	CRITICAL
CVSS v3.0 Base Score:	9.8
CVSS v3.0 Vector:	CVSS:3.0/AV:N/AC:L/CP:N/AU:C/MAJ:H
CVSS v2.0 Base Score:	10.0
CVSS v2.0 Vector:	CVSS:2.0/AV:N/AC:L/AU:C/MAJ:H

Vulnerability Information

In the News: True

Dettaglio del finding SSL utilizzato come riferimento per la remediation.

```

msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900        0.0.0.0:*          LISTEN     5052/Xtightvnc
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900        0.0.0.0:*          LISTEN     5052/Xtightvnc
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep -E ':25|:5432'
tcp        0      0 0.0.0.0:5432        0.0.0.0:*          LISTEN     4256/postgres
tcp        0      0 0.0.0.0:25          0.0.0.0:*          LISTEN     4411/master
tcp6       0      0 :::5432             :::*                LISTEN     4256/postgres
msfadmin@metasploitable:~$

```

Figura 10 – Verifica dei servizi SMTP e PostgreSQL.

Verifica dei servizi SMTP e PostgreSQL sulle porte 25 e 5432.

5. Stato della remediation prima della scansione finale

Finding	Stato dell'intervento
61708 – VNC Server 'password' Password	Password sostituita e VNC riavviato
51988 – Bind Shell Backdoor Detection	Traffico TCP/1524 bloccato con iptables
20007 – SSL Version 2 and 3 Protocol Detection	Configurazione SMTP modificata; verifica conclusiva con Nessus
201352 – Ubuntu Linux SEoL	Nessuna modifica: sistema operativo legacy mantenuto

A questo punto la macchina era pronta per la scansione finale. La validazione definitiva degli interventi viene riportata nel documento ScansioneFine.